

FASE 1: INVENTARIO Y DIAGNÓSTICO INICIAL

1.1. Levantamiento de información

Versión del sistema

lsb_release -a

uname -a

Servicios y puertos

ss -tulpn

netstat -tulpn

Usuarios y grupos

cat /etc/passwd

cat /etc/group

getent passwd

Paquetes instalados

dpkg -l

snap list

Procesos en ejecución

ps auxf

top -b -n 1

Revisión de permisos de archivos críticos:

Ver permisos de archivos importantes

ls -l /etc/passwd /etc/shadow /etc/sudoers

Buscar archivos con permisos peligrosos

find / -perm -4000 -type f 2>/dev/null

archivos SUID

find / -perm -2000 -type f 2>/dev/null

archivos SGID

1.2. Herramientas de auditoría inicial

Instalar herramientas básicas

```
apt update
```

```
apt install lynis audited chkrootkit rkhunter clamav -y
```

Ejecutar auditoría Lynis

```
lynis audit system
```

Buscar rootkits

```
chkrootkit
```

```
rkhunter --check
```

Análisis de malware

```
clamscan -r /
```

FASE 2: HARDENING DEL SISTEMA BASE

2.1. Actualizaciones y parches

Configurar actualizaciones automáticas

```
apt install unattended-upgrades
```

```
dpkg-reconfigure --priority=low unattended-upgrades
```

Configurar en /etc/apt/apt.conf.d/50unattended-upgrades

2.2. Configuración del kernel y sysctl

Protecciones de red en /etc/sysctl.conf

```
net.ipv4.conf.all.rp_filter=1
```

```
net.ipv4.conf.default.rp_filter=1
```

```
net.ipv4.tcp_syncookies=1
```

```
net.ipv4.conf.all.accept_redirects=0
```

```
net.ipv6.conf.all.accept_redirects=0
net.ipv4.conf.all.send_redirects=0
net.ipv4.icmp_echo_ignore_broadcasts=1
net.ipv4.icmp_ignore_bogus_error_responses=1
```

2.3. Particiones y montajes seguros

```
# /etc/fstab con opciones seguras
tmpfs /tmp tmpfs defaults,nosuid,noexec,nodev 0 0
tmpfs /var/tmp tmpfs defaults,nosuid,noexec,nodev 0 0
tmpfs /dev/shm tmpfs defaults,nosuid,noexec,nodev 0 0
```

FASE 3: GESTIÓN DE ACCESOS Y AUTENTICACIÓN

3.1. Políticas de contraseñas

```
# /etc/pam.d/common-password
password requisite pam_pwquality.so retry=3 minlen=12 difok=3
ucredit=-1 lcredit=-1 dcredit=-1 ocredit=-1
```

```
# /etc/login.defs
PASS_MAX_DAYS 90
PASS_MIN_DAYS 7
PASS_WARN_AGE 14
```

3.2. Autenticación SSH

```
# /etc/ssh/sshd_config
Port 2222 # Cambiar puerto
PermitRootLogin no
PubkeyAuthentication yes
PasswordAuthentication no
X11Forwarding no
MaxAuthTries 3
```

```
ClientAliveInterval 300  
ClientAliveCountMax 0  
Protocol 2
```

3.3. Control de acceso sudo

```
# Limitar sudoers  
visudo  
# Configurar:  
%admin ALL=(ALL) ALL  
Defaults logfile=/var/log/sudo.log
```

FASE 4: HARDENING DE SERVICIOS

4.1. Firewall (UFW/iptables)

```
# Configurar UFW  
ufw default deny incoming  
ufw default allow outgoing  
ufw allow 2222/tcp # Puerto SSH  
ufw enable
```

```
# Reglas iptables avanzadas  
iptables -P INPUT DROP  
iptables -P FORWARD DROP  
iptables -P OUTPUT ACCEPT
```

4.2. Deshabilitar servicios innecesarios

```
systemctl list-units --type=service  
systemctl disable [servicio]  
apt remove --purge [paquete-no-necesario]
```

4.3. Servidores web y bases de datos

- # Apache/NGINX: Headers de seguridad
- # MySQL: mysql_secure_installation
- # Deshabilitar métodos HTTP peligrosos

FASE 5: MONITOREO Y DETECCIÓN

5.1. Logs y auditoría

- # Instalar y configurar auditd
 - apt install auditd
 - auditctl -e 1
- # Reglas de auditoría
 - w /etc/passwd -p wa -k identity
 - w /etc/shadow -p wa -k identity
 - w /etc/sudoers -p wa -k sudoers
 - w /var/log/auth.log -p wa -k auth

5.2. IDS/IPS

- # AIDE (Integridad de archivos)
 - apt install aide
 - aideinit
 - mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
- # Falco o OSSEC para detección en tiempo real

5.3. Logs centralizados

- # rsyslog o syslog-ng
- # Configurar forwarding a servidor SIEM

FASE 6: HERRAMIENTAS DE SECURIZACIÓN AVANZADA

6.1. AppArmor o SELinux

Verificar estado

aa-status

Activar AppArmor

systemctl enable apparmor

systemctl start apparmor

6.2. Fail2ban

apt install fail2ban

cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local

Configurar protecciones SSH, web, etc.

6.3. ClamAV y Rootkit hunters

Actualizar y programar escaneos diarios

freshclam

clamscan -r --bell -i /

FASE 7: BACKUP Y RECUPERACIÓN

7.1. Estrategia de backups

3-2-1 rule

Automatizar con rsync, duplicity, BorgBackup

Encriptar backups

7.2. Plan de respuesta a incidentes

1. Detección y análisis

2. Contención

3. Erradicación

4. Recuperación

5. Lecciones aprendidas

FASE 8: VERIFICACIÓN Y CUMPLIMIENTO

8.1. Checklist de seguridad

- CIS Benchmarks aplicados
- Puertos cerrados excepto necesarios
- Autenticación multifactor implementada
- Políticas de contraseñas vigentes
- Sin contraseñas por defecto
- Servicios actualizados
- Monitoreo activo

8.2. Escaneo de vulnerabilidades

Instalar OpenVAS o usar herramientas cloud

apt install openvas

8.3. Pruebas de penetración

nmap, nikto, sqlmap, metasploit (entorno controlado)

FASE 9: MANTENIMIENTO CONTINUO

9.1. Automatización

Scripts de hardening (bash, Ansible)

Actualizaciones automáticas

Escaneos programados

9.2. Documentación

- Línea base de configuración
- Cambios realizados
- Responsables
- Políticas de seguridad
- Procedimientos operativos

9.3. Capacitación

- Buenas prácticas para administradores
- Uso seguro por usuarios finales
- Respuesta ante incidentes

HERRAMIENTAS RECOMENDADAS

Herramienta	Función	Prioridad
Lynis	Auditoría general	Alta
UFW/iptables	Firewall	Alta
Fail2ban	Protección brute-force	Alta
Auditd	Auditoría de sistema	Media
ClamAV	Antivirus	Media
AIDE	Integridad archivos	Media
AppArmor	MAC	Media
OpenSCAP	Cumplimiento	Baja

Esta hoja de ruta es iterativa y debe adaptarse al propósito específico de la máquina (servidor, workstation, contenedor, etc.) y al nivel de seguridad requerido.